

Active Directory in Operational Technology & Industrial Control Systems

Identity-Centric Security Framework for Smart Manufacturing and the Path to Industry 4.0 Resilience

- By: Pradeep Kumar Rayapuram Karanam - Sr. Manager Identity & Access Management | Active Directory | Zero Trust

ZERO TRUST Verify Every Identity	AI / UEBA Behavioural Analytics	TIER-0 HCI AD Core on Azure Stack HCI
PQC READY CRYSTALS-Kyber FIPS 203/204	SOC / SIEM Unified OT/IT Monitoring	DIGITAL TWIN Validate Before Production

78 %	\$50K+ /h	65 %	2030
Of manufacturing cyberattacks target OT systems directly	Average OT downtime cost per hour during a breach	Manufacturers without OT-specific IAM controls	NIST IR 8547 post-quantum migration deadline

Table of Contents

Table of Contents.....	2
. Executive Summary and Strategic Vision.....	3
1. Introduction to OT/ICS Security.....	4
2. Why Active Directory in OT/ICS Environments	5
3. Why Active Directory Cannot Be Replaced.....	6
4. Security Challenges in OT/ICS Environments	7
Legacy Infrastructure and Technical Debt.....	7
Network Architecture Complexity.....	7
Visibility, Detection, and Response Deficits	7
Regulatory, Safety, and Business Criticality	7
5. Purpose-Built AD Deployment for OT/ICS	8
6. Tier-0 AD on Azure Stack HCI & Zero Trust.....	9
Azure Stack HCI for Tier-0 Resilience	9
Zero Trust Access Controls for Tier-0 Administration	9
7. AI-Enhanced Identity Analytics for OT/ICS	10
8. SOC Visibility and Monitoring for OT Operations.....	11
9. Post-Quantum Crypto & Digital Twin Readiness.....	12
10. Automotive Smart Factory Case Studies	13
Case Study 1: Stellantis – Global OEM, Engine & EV Manufacturing.....	13
Case Study 2: Continental – Tier-1 Supplier, 18 Global Plants	13
Case Study 3: LG Energy Solution – Greenfield EV Battery Plant.....	14
11. Conclusion: Realizing Trusted Automation.....	14
Zero Trust as Operational Reality.....	14
Digital Twin Validation as Operational Standard.....	14
The Path to Immediate Action	15
12. Strategic Roadmap and Key Focus Areas	16
References and Authoritative Sources.....	17
A. Standards and Regulatory Frameworks.....	17
B. Microsoft Technical Documentation.....	17
C. Field Research and Threat Intelligence	17
D. Post-Quantum Cryptography Standards.....	17
E. Automotive and Smart Manufacturing Case Studies.....	17

Executive Summary and Strategic Vision

After extensive architecture reviews, tabletop exercises with OT engineers, hands-on pilot assessments, and targeted threat intelligence analysis, a consistent and actionable conclusion has emerged: **the transition to Industry 4.0 in automotive manufacturing will succeed only when security is elevated from a compliance checkbox to an operational capability.** The convergence of IT and OT unlocks extraordinary efficiency, yet it simultaneously multiplies attack surfaces, extends the timescale of risk, and exposes fragile dependencies that legacy architectures were never designed to address.

Central to a resilient OT security posture is **Active Directory acting as the operational identity control plane.** AD anchors authentication and authorisation for users, service accounts, and devices; consolidates configuration policy through Group Policy; and generates the telemetry and audit streams, logon events, privilege changes, replication health, and certificate operations, that feed AI analytics, SIEMs, and digital twin simulations. Organisations best positioned to realise Industry 4.0 value are those that make **identity, validation, and adaptability the organising principles of their security posture.**

Industry 4.0 is reshaping the manufacturing landscape with advanced automation, connected assets, and data-driven operations. While these capabilities accelerate productivity and innovation, they also expose operational technology (OT) to an unprecedented cyber-risk surface. Securing identity, the new control plane for both human and machine access, has become a board-level priority.

This white paper provides a strategic blueprint for implementing identity-first security across OT/ICS environments, positioning Active Directory as the foundational identity provider and operational trust anchor. The framework distils field experience from large-scale industrial deployments into six executive-critical pillars:

1. Strategic Rationale for Active Directory in OT:

Why AD remains the most viable identity platform for hybrid, latency-sensitive, and air-gapped factory environments and where cloud-only identity models fall short in high-assurance operations.

2. Resilient Tier-0 Architecture on Azure Stack HCI:

A hardened deployment model that delivers the reliability, isolation, and survivability required for mission-critical factory operations even during network outages or hostile events.

3. Zero Trust for Industrial Operations:

A pragmatic, OT-aligned Zero Trust framework that enforces strong authentication, least privilege, and segmentation across human operators, robots, controllers, and machine identities.

4. AI-Driven Threat Analytics in the Factory:

How UEBA and advanced AI models detect insider anomalies, compromised accounts, and abnormal machine-to-machine interactions before they impact production.

5. Post-Quantum Cryptography Roadmap:

A leadership view of the transition to PQC, aligned to NIST IR 8547 guidance — ensuring long-term cryptographic resilience across identity systems and control networks.

6. Digital-Twin Validation & Measurable ROI:

Evidence from three automotive manufacturing programs demonstrating how identity-first security delivered measurable gains in uptime, risk reduction, and operational efficiency.

This white paper equips technology and security leaders with a clear, actionable roadmap to modernize OT identity, strengthen factory cyber-resilience, and accelerate safe Industry 4.0 adoption at enterprise scale.

1. Introduction to OT/ICS Security

Figure 1 — Purdue Reference Model: Five OT/ICS Network Zones with AD Identity Coverage

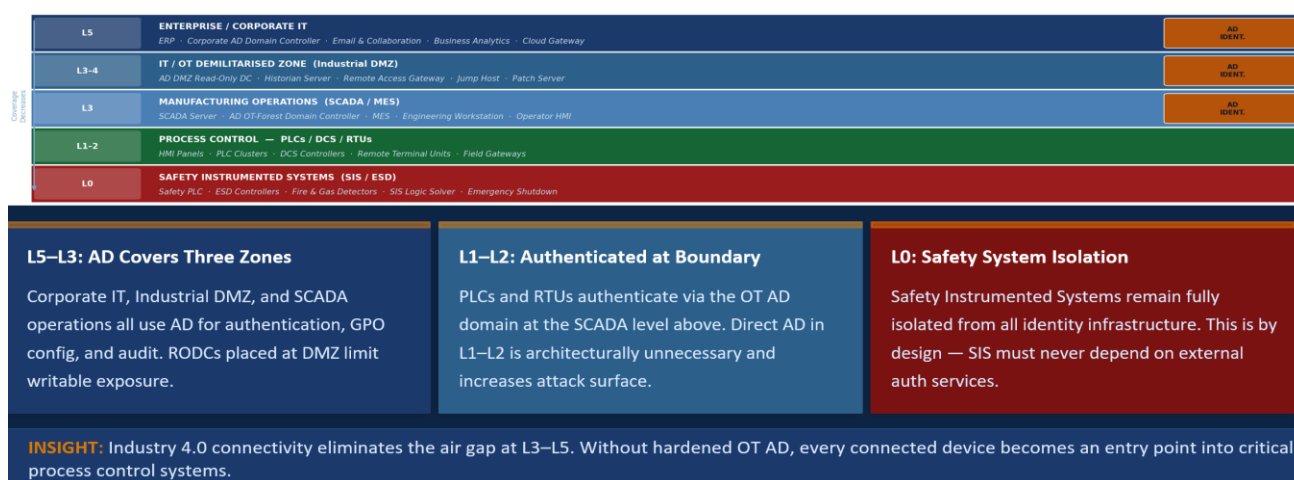


Figure 1 — Purdue Reference Model: Five OT/ICS Network Zones with AD Identity Coverage (L3–L5). Level 0 (Safety Systems) through Level 5 (Enterprise IT).

Operational Technology (OT) and **Industrial Control Systems (ICS)** encompass the hardware, software, and networks that monitor and control physical processes in manufacturing, energy, utilities, water treatment, and transportation. Unlike enterprise IT — where confidentiality typically dominates the security priority hierarchy — OT/ICS places **safety, availability, and process integrity above all else**. A security failure is not limited to data loss; it extends to physical harm, environmental damage, production halts, and multi-jurisdictional regulatory violation.

The industry 4.0 agenda connects factory-floor OT with enterprise IT and cloud services, unlocking real-time visibility, predictive maintenance, and quality analytics. However, this same convergence broadens the attack surface and compromises previously air-gapped environments. Ransomware, credential theft, and supply-chain intrusions now reach production floors with immediate physical consequence. Legacy controllers, diverse industrial protocols (Modbus, DNP3, Ethernet/IP, PROFINET), and near-constant uptime requirements make cloud-centric IAM insufficient without on-premises Active Directory as the **identity backbone**.

Threat Vector	Description	Sectors Affected	Impact
Ransomware on OT Systems	Encrypts control systems; halts production lines and safety processes	Manufacturing, Energy	Critical
AD Credential Theft & Lateral Movement	Stolen AD credentials enable pivot from IT into OT production zones	All Sectors	Critical
ICS-Specific Malware (EKANS, TRITON)	Targets PLCs, DCS, safety systems — disrupts control logic directly	Auto, Energy, Utilities	Critical
Supply Chain & Vendor Access Abuse	Compromised third-party remote access paths into OT control networks	Manufacturing, Defence	High
Legacy Protocol Exploits (Modbus/DNP3)	Unauthenticated protocols enable spoofing and replay attacks on PLCs	Manufacturing, Water	High
Insider Privilege Misuse	Excess privileges cause configuration drift, sabotage, and accidental outage	All Sectors	High

2. Why Active Directory in OT/ICS Environments

Figure 2 — Six Structural AD Capabilities for OT/ICS (Unavailable in Cloud-Only IAM)

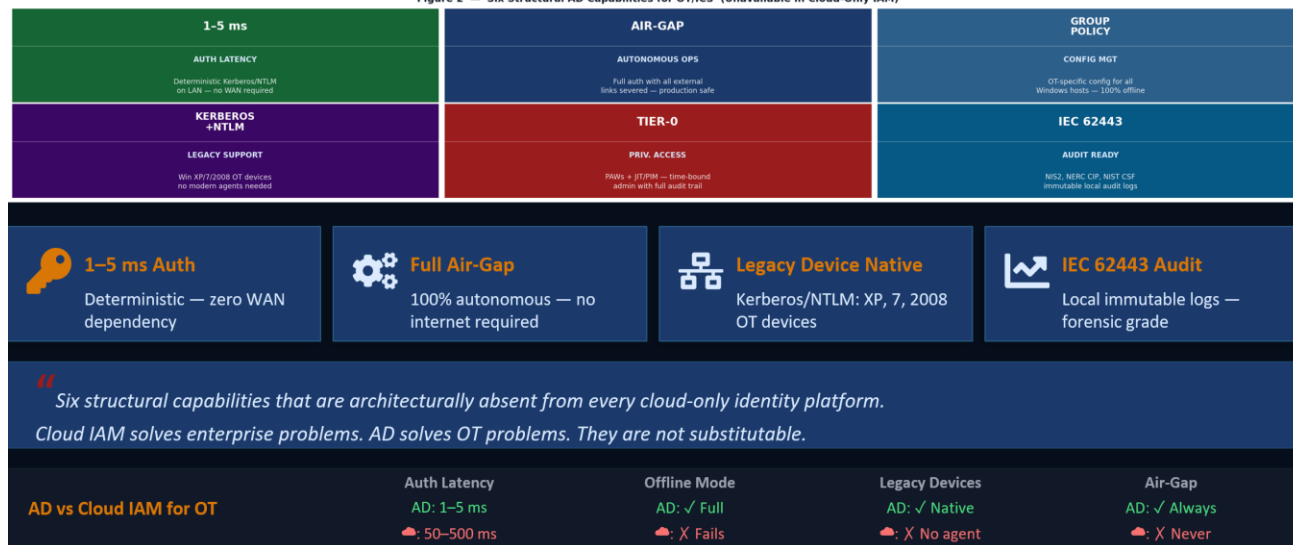


Figure 2 — Six Structural AD Capabilities for OT/ICS. Each cell shows metric value, capability name, and operational significance. All six are unavailable in cloud-only IAM.

Active Directory provides six structural capabilities that are absent in cloud-only identity platforms — each directly addressing a critical OT/ICS operational requirement. In these environments, delayed or failed authentication means stalled HMIs, halted PLC operations, and disabled safety interlocks. Identity services must be **predictable, fast, and available even when upstream networks are unavailable**.

Criterion	Cloud-Only IAM — OT Limitation	Active Directory — OT Advantage
Authentication Latency	50-500+ ms WAN-dependent — variable, unpredictable under load	1-5 ms deterministic LAN — zero WAN or cloud dependency ever
Air-Gap / Offline Operation	Requires internet for every authentication — fails completely when offline	Fully autonomous — operates completely isolated, no internet required
Legacy Device Support	SAML/OIDC/OAuth requires modern OS agents — unavailable on legacy OT	Kerberos/NTLM native for Windows XP, 7, 2008 OT devices without agents
Configuration Governance	MDM/cloud policy lacks OT legacy device depth and offline applicability	Group Policy: deterministic, auditable, fully offline OT config delivery
Regulatory Audit Compliance	SLA-dependent cloud trails fail ICS forensic integrity requirements	Local immutable audit: IEC 62443, NIS2, NERC CIP, NIST CSF aligned
OT Vendor Integration	Re-certification required: 12-36 months downtime per plant	Decades of validated Siemens, Rockwell, ABB, Honeywell, Schneider support

3. Why Active Directory Cannot Be Replaced

Can AD be replaced by a modern cloud identity platform? For most OT/ICS environments, the answer is **not without significant operational risk and a 3–5-year infrastructure redesign programme**. Six structural dimensions make replacement impractical in most deployment contexts:

Six structural barriers make cloud-only migration operationally dangerous

Legacy Devices Up to 70% of OT estate uses Windows XP/7/2008 — no modern IdP agents exist for these platforms	Air-Gap Operation All cloud IAM requires internet — fails 100% at air-gapped nuclear, defence, and critical sites	Auth Latency 50–500ms WAN vs 1–5ms local AD — variance directly causes safety system failure in PLCs and HMIs
Group Policy GPO delivers offline OT configuration — MDM/cloud policy has no offline OT equivalent	Regulatory Audit IEC 62443, NERC CIP, NIS2 require local deterministic forensic logs — cloud SLA logs do not qualify	Vendor Integration 12–36 months downtime per plant to re-certify existing OT equipment with any alternative IdP

Dimension	Why AD Cannot Be Replaced	Alternative Limitation	Replacement Risk
Legacy Device Support	HMIs, PLCs, SCADA on Windows XP/7/2008 use only Kerberos/NTLM — no modern protocol support	Cloud IdPs require modern OS agents — unavailable on legacy embedded OT hardware	Auth failure for up to 70 % of OT estate immediately
Air-Gap Operation	Nuclear, defence, critical manufacturing require auth with zero internet connectivity	All cloud IAM requires internet — fails completely at air-gapped or isolated sites	Complete auth failure at all isolated facilities
Authentication Latency	Safety-critical OT requires deterministic 1–10 ms. Local AD delivers this reliably	WAN-dependent 50–500+ ms with variance — direct safety system failure risk	Safety failures; unplanned production halts; SIL degradation
Group Policy	GPO delivers granular, deterministic OT configuration management — offline capable	MDM/cloud policy lacks OT legacy device depth and offline compatibility	Configuration drift; expanded attack surface; compliance gaps
Regulatory Compliance	IEC 62443, ISO/SAE 21434, NERC CIP, NIS2 require local deterministic audit trails	Cloud IAM SLA-dependent logs fail ICS forensic integrity requirements	Compliance violations; failed audits; regulatory enforcement risk
Vendor Integration	Siemens, Rockwell, Honeywell, ABB, Schneider: decades of validated AD integration	Re-certifying OT with alternative IdPs: 12–36 months downtime per plant	Multi-year, multi-million migration with full operational exposure

“For most OT/ICS environments, Active Directory remains the pragmatic, proven identity platform. The path forward is to harden, isolate, and augment AD — not to replace it.”

— Digital Bond: Active Directory in ICS — Lessons Learned from the Field · CISA ICS-CERT Advisory

4. Security Challenges in OT/ICS Environments

Legacy Infrastructure and Technical Debt

Many OT environments depend on decades-old platforms – Windows XP Embedded, legacy UNIX variants, and proprietary real-time operating systems – that no longer receive vendor security updates. Mean time to patch in OT typically ranges from weeks to several months, dramatically increasing attacker dwell time and operational exposure compared to enterprise IT.

Network Architecture Complexity

Industrial networks are multi-zone, multi-protocol fabrics with different latency, reliability, and trust requirements at each Purdue level. Remote access for contractors and vendors introduces further risk through shared credentials, poorly governed gateways, and permanently enabled access channels that violate the principle of least privilege.

Visibility, Detection, and Response Deficits

Without continuous asset-level visibility, passive network sensors at zone boundaries, and identity signals from local AD, security teams cannot correlate anomalous device behaviour with compromised credentials. OT system recovery requires validated, tested procedures – and many safety-critical assets cannot be rapidly rebuilt from backup under operational pressure.

Regulatory, Safety, and Business Criticality

OT failures cause physical harm, environmental damage, and regulatory non-compliance alongside financial loss. Automotive manufacturers operate under IEC 62443, ISO/SAE 21434, NIS2, and where applicable NERC CIP. Security posture is intrinsic to operational safety, product quality assurance, and revenue continuity – not a separate IT concern.

Recommended Mitigations and Design Principles

- ▶ Deploy local, hardened AD DCs inside OT zones – never rely on WAN-dependent or cloud authentication for production systems
- ▶ Apply strict segmentation per IEC 62443 zone/conduit model with OT-aware firewall and IDS policy at each zone boundary
- ▶ Deploy passive network sensors (Claroty, Dragos, Nozomi) for continuous OT asset inventory and anomaly detection
- ▶ Enforce least-privilege access and Privileged Access Workstations (PAWs) for every administrator at every Tier level
- ▶ Establish and quarterly-test immutable AD backups and identity recovery playbooks with formally defined RTO/RPO targets
- ▶ Formalise all remote vendor support: dedicated jump hosts, time-bound JIT access, mandatory MFA, full session recording

5. Purpose-Built AD Deployment for OT/ICS

OT/ICS environments require identity architecture that delivers local, low-latency authentication and prevents lateral movement from compromised corporate systems. Active Directory must be deployed and operated as a **mission-critical, safety-adjacent operational service** – not as a convenience IT component shared with corporate users.

Deployment Model	Description	Air-Gap	Isolation	Best Use Case
Isolated OT Forest	Standalone AD forest exclusively for OT. No IT→OT lateral movement possible. Independent AD CS PKI root.	Full	Maximum	Nuclear, defence, critical infrastructure, high-assurance manufacturing
Dedicated OT Domain	Dedicated OT domain with explicit, minimal cross-forest trusts to corporate AD. Balances security and operational efficiency.	Full	High	Mid-size manufacturers with mixed IT/OT operational requirements
Writable DCs + GC in OT	Full writable DCs with Global Catalog inside OT zones. Deterministic auth during WAN and cloud outages.	Full	Good	Sites requiring maximum authentication determinism and GC query performance
Read-Only DCs (RODC)	Reduces writable credential exposure at sites with limited physical security controls.	Partial	Good	Remote sites, edge facilities, and substation environments

AD Hardening Checklist for OT/ICS Deployment

- ▶ Deploy dedicated OT AD forest or tightly segmented OT domain – never share DCs between IT and OT networks
- ▶ Place full writable DCs with Global Catalog inside each OT zone for deterministic, LAN-speed authentication
- ▶ Restrict all Tier-0 administration to PAWs with MFA enforced; time-bound JIT elevation via Entra PIM
- ▶ Verify Kerberos time sync accuracy (<5 min skew), DNS redundancy, and secure NTP source at each site
- ▶ Stream all AD event logs, AD CS certificate events, and replication health to OT SIEM continuously
- ▶ Conduct AD disaster recovery exercises quarterly – validate RTO/RPO for every Tier-0 service component

6. Tier-0 AD on Azure Stack HCI & Zero Trust

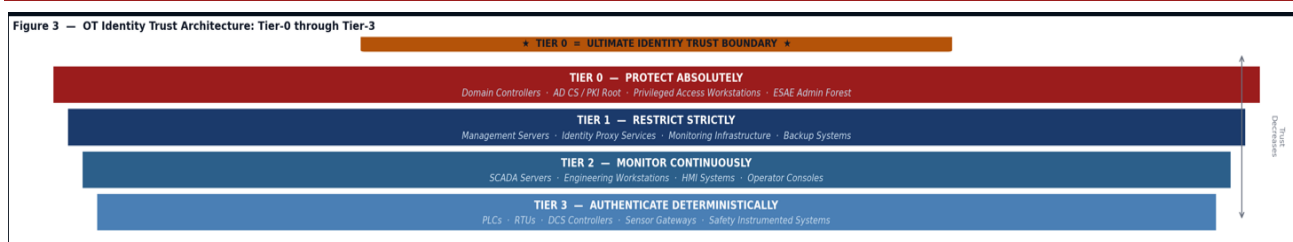


Figure 3 — OT Identity Trust Architecture: Tier-0 through Tier-3. AD at Tier 0 is the ultimate trust boundary. Every lower tier depends on it for authentication, Group Policy, and PKI.

Tier-0 AD infrastructure must be treated as an operational, safety-critical system. A Tier-0 compromise means authentication services, certificates, and directory replication can be disrupted or corrupted — with immediate safety, production, and regulatory consequence. **AD must be architected and operated as Tier-0 infrastructure, not managed ad-hoc.**

Azure Stack HCI for Tier-0 Resilience

HCI Capability	OT Security Benefit	Technical Specification
Local HA Clustering	Eliminates single points of DC failure for sustained authentication availability	1–16 node clusters; stretched multi-site clusters for WAN-resilient deployments
NVMe + RDMA Storage	Sub-second VM failover ensures deterministic authentication continuity	Storage Spaces Direct with NVMe: consistent low-latency DC I/O performance
Fully Disconnected Mode	All auth, Group Policy, and AD CS operations with zero Azure cloud dependency	Azure Local operates fully air-gapped from Azure management plane — tested and validated
BitLocker + Immutable Backups	Host-level encryption and protected recovery for all critical Tier-0 AD assets	Encrypted backup + off-site immutable copies + documented and tested recovery playbooks
Azure Arc (Optional)	Centralised health telemetry and policy compliance integrated with OT SIEM	Arc optional — all Tier-0 functionality available in fully disconnected mode

Zero Trust Access Controls for Tier-0 Administration

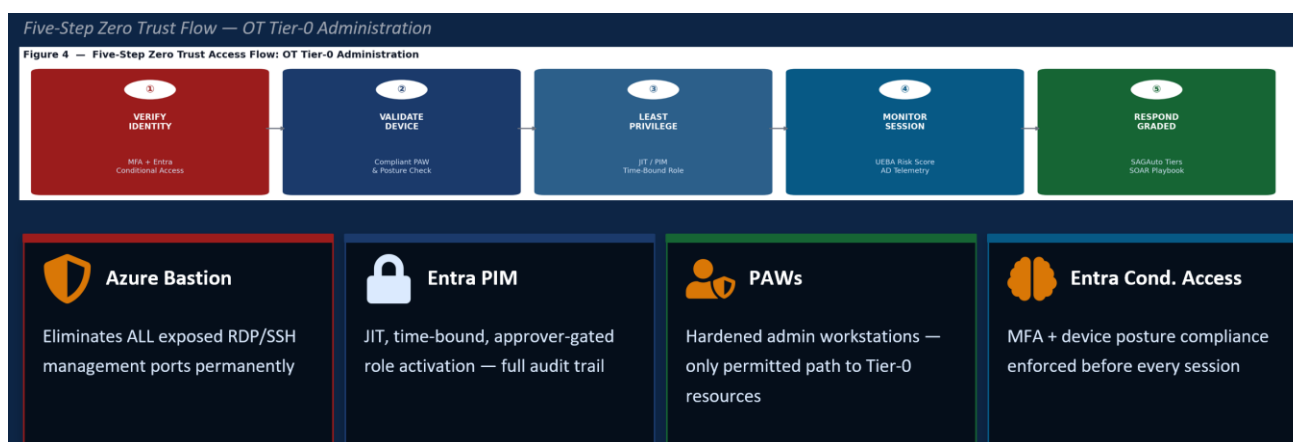


Figure 4 — Five-Step Zero Trust Access Flow: Identity verification, device validation, least-privilege JIT, continuous UEBA monitoring, and SAGA Auto graded automated response.

Azure Bastion eliminates all exposed RDP/SSH management ports. **Entra Conditional Access** restricts sessions to verified identities on compliant PAWs. **Entra PIM** enforces just-in-time, time-bound, approver-gated

role activations. **Read-Only DCs** at remote sites limit writable credential exposure at physically unsecured locations. Together, these controls create a Zero Trust administration posture that is **more secure and operationally resilient than traditional always-on admin access**.

7. AI-Enhanced Identity Analytics for OT/ICS

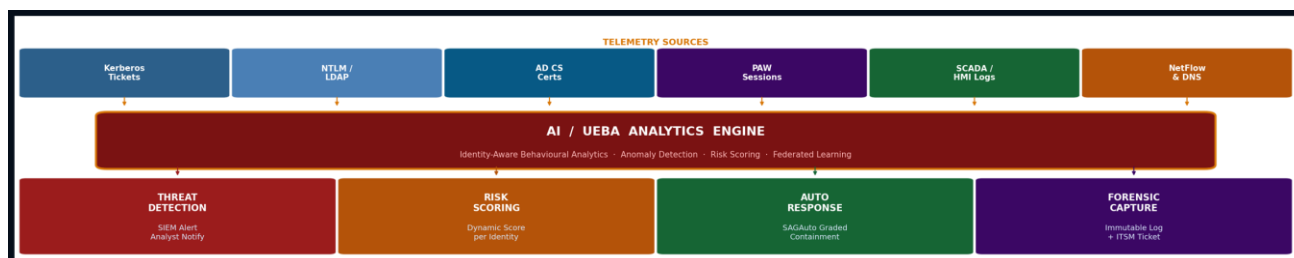


Figure 5 – AI/UEBA Analytics Pipeline: Six telemetry sources feed the analytics engine, producing four graded output streams with 100 % forensic capture on every automated action.

Identity-aware behavioural analytics and federated learning materially increase detection fidelity while respecting data sovereignty across dispersed global plants. UEBA models trained on OT-specific identity baselines – normal Kerberos ticket patterns for PLC service accounts, expected certificate lifecycle for SCADA hosts, typical PAW session duration for shift engineers – dramatically reduce false positives while surfacing genuine compromise indicators earlier in the kill chain.

Only explainable, adversarially-hardened models that have been validated in digital twin environments should drive automated remediation for safety-critical operations. The SAGAuto framework provides four graded response tiers that maintain safety system integrity while containing threats at machine speed.

95 %	–60%	<3 s	100 %
Anomaly detection accuracy target	False positive reduction vs static rules	Average automated response time	Forensic capture on all auto-actions

Operationalising AD + AI Analytics in OT Environments

- ▶ Ingest identity telemetry: DC event logs, AD CS events, PAW audit trails, RODC cache events, NetFlow data
- ▶ Correlate with OT process sources: SCADA/HMI logs, PLC telemetry, protocol inspection (Modbus, DNP3, EtherNet/IP)
- ▶ Host all UEBA analytics on on-premises HCI – never transmit raw OT identity telemetry to external cloud platforms
- ▶ SAGAuto four-tier automation: Advisory → Notify → Soft Containment → Hard Containment with safety gates
- ▶ Enforce model governance: labelled OT training datasets, adversarial twin validation, and ongoing drift monitoring
- ▶ Every automated action generates an immutable forensic snapshot and routes to the ITSM incident queue automatically

8. SOC Visibility and Monitoring for OT Operations

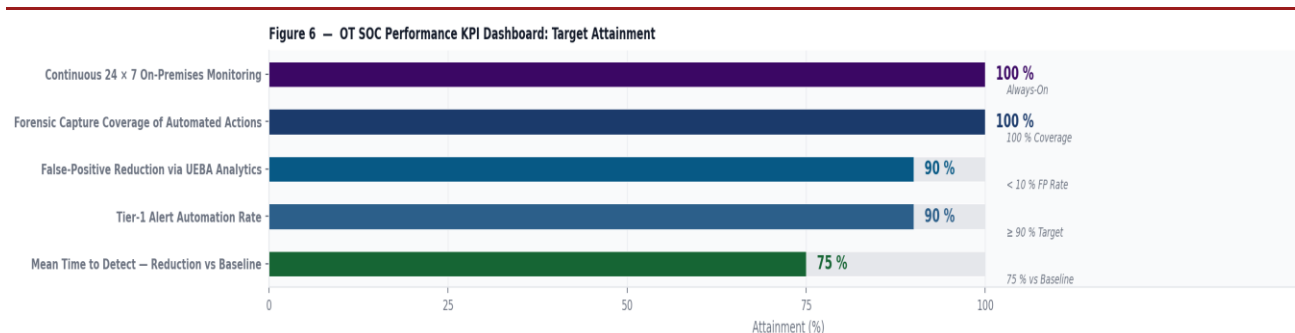


Figure 6 – OT SOC Performance KPI Dashboard: Five key indicators with quantitative targets and attainment bars. MTTD and automation rate are the primary success measures.

An OT SOC must consume three signal streams concurrently: high-fidelity identity telemetry from Tier-0 AD; process-aware network telemetry from the OT floor (Levels 0–3); and on-premises AI/UEBA analytics output. The integration of these streams produces actionable, low-noise detections with full forensic integrity – far superior to either IT-only SIEM or standalone OT monitoring in isolation.

Kerberos ticket analysis, AD CS certificate events, Group Policy change auditing, and PAW session trails map directly to known compromise indicators. Correlated with SCADA/HMI logs and PLC telemetry, they enable **identity-anchored threat detection across both the IT/OT boundary and within the OT network itself.**

SOC KPI	Target	Measurement Method	Safety Constraint
Mean Time to Detect (MTTD)	75 % reduction vs baseline	Alert timestamp vs confirmed event timestamp in SIEM	Must not trigger false alerts that reach safety systems
Mean Time to Respond (MTTR)	Bounded by plant production impact SLA	Ticket creation timestamp to containment close	Must not interrupt safety-critical control loops
Tier-1 Automation Rate	≥90 % of routine Tier-1 alerts	SOAR playbook auto-execution ratio	All actions require SAG Auto gate validation first
False Positive Rate	<10 % with UEBA threshold tuning	Analyst escalation audit and false-close review	FP-driven shutdowns are operationally unacceptable
Forensic Capture	100 % of all automated actions	Automated log completeness audit daily	Required: IEC 62443, NIS2, ISO/SAE 21434
Continuous Coverage	Always-on on-premises analytics	Platform availability SLA monitoring	On-premises hosting mandatory – no cloud dependency

9. Post-Quantum Crypto & Digital Twin Readiness



Figure 7 — Post-Quantum Cryptography Migration Roadmap: Five tracks across four phases with completion fill-bars. Aligned to NIST FIPS 203/204 (August 2024) and NIST IR 8547.

Future readiness is non-negotiable for OT identity infrastructure. OT device lifecycles of 10–20 years mean equipment purchased and installed today will remain operational inside the 2030–2035 NIST IR 8547 quantum cryptography transition window. “Harvest-now, decrypt-later” attacks are already operationally viable for nation-state adversaries targeting long-lived OT certificate traffic and authentication material.

NIST finalised **FIPS 203 (CRYSTALS-Kyber)** for key encapsulation and **FIPS 204 (CRYSTALS-Dilithium)** for digital signatures in August 2024. The migration roadmap prioritises Tier-0 domain controller TLS channels and AD CS root CA first — the assets that, if compromised, provide the broadest cryptographic leverage to an adversary. **Digital twins proved indispensable** across all pilot programmes for testing access policies, patch procedures, UEBA playbooks, and PQC algorithm swaps before any contact with production systems.

Technology	2024–2025	2025–2027	2027–2030	2030–2035
Digital Twins	Scope OT twin: DCs, AD CS, key control loops	Production deployment for all change validation	Full AD/PKI/SCADA twin coverage	Mandatory twin-first for all prod changes
Post-Quantum Crypto	Inventory certs; gap assessment; vendor engagement	Hybrid classical + PQC pilot on Tier-0 DCs	PQC primary for all Tier-0 and AD CS	Full quantum-safe OT estate – FIPS 203/204
Autonomous AI Security	UEBA advisory monitoring and baselining only	Automated soft containment (non-safety zones)	Self-healing playbooks via SAGAuto	Autonomous SOC for defined OT use cases
Quantum-Safe OT Protocols	Vendor lab assessment for Modbus/DNP3 PQC	Lab compatibility pilots in test environment	Production pilot in selected facilities	Industry-standard quantum-safe OT protocols

10. Automotive Smart Factory Case Studies



Figure 8 — Three Automotive Case Study Outcomes: Measurable security and operational ROI from identity-first, AD-centric frameworks across Tier-0, AI analytics, and digital twin.

Three automotive sector deployments demonstrate that an identity-first, AD-centric OT security framework delivers measurable and repeatable results across different organisational scales, plant footprints, and security maturity levels.

Case Study 1: Global OEM, Engine & EV Manufacturing

Challenge	Modernise multi-site engine assembly with connected robotics and real-time quality analytics while maintaining production uptime SLAs, securing industrial IoT at scale, and achieving ISO/SAE 21434 compliance across the full vehicle cybersecurity engineering lifecycle.
Solution	Deployed an isolated OT AD forest on Azure Stack HCI with two writable DCs per zone. Micro segmentation with Industrial DMZ and time-bound JIT vendor access via Entra PIM. A live digital twin mirrored all DCs, AD CS, and PLC traffic — enabling GPO changes, PAW workflows, and SOAR playbooks to be validated before production deployment.
Results	40 % reduction in security incidents · Zero auth-related production downtime · ISO/SAE 21434 compliance achieved · Multimillion-dollar annual risk reduction
Source	Stellantis — AI-enabled manufacturing efficiency programme, September 2024.

Case Study 2: Tier-1 Supplier, 18 Global Plants

Challenge	Standardise identity governance and access control across 18 global manufacturing plants with differing connectivity, varying regulatory requirements, and significant security maturity gaps between older brownfield and newer greenfield facilities.
Solution	Geo-segmented Micro Forest AD architecture: one regional AD domain per jurisdiction, each with local writable DCs for autonomous operation, standardised GPO baseline templates, and selective one-way trusts feeding a centralised OT SOC. Azure Arc provided hybrid policy orchestration without requiring cloud dependency for production authentication.
Results	60 % reduction in identity management overhead · Consistent compliance across all 18 regions · Unified OT SOC visibility · Faster cross-site incident detection and response
Source	Continental AG — vehicle cybersecurity and production security programme, 2024.

Case Study 3: Greenfield EV Battery Plant

Challenge	Design and commission a complete identity and security architecture for a new EV battery gigafactory from day one – with explicit post-quantum cryptography agility and Zero Trust access controls embedded from initial infrastructure build.
Solution	Digital twin commissioned pre-production; all security controls validated in twin before any hardware commissioning. PKI designed for hybrid classical + CRYSTALS-Kyber PQC readiness. Edge AI threat detection on private 5G fabric. All Tier-0 services protected by PAWs and Entra-controlled JIT from the first production day.
Results	Near-perfect uptime from commissioning · Zero security incidents in first 18 months · PQC-ready architecture adopted as industry reference · Accelerated compliance certification
Source	LG Energy Solution / Siemens / Honeywell – manufacturing intelligence partnership, 2023–2024.

11. Conclusion: Realizing Trusted Automation

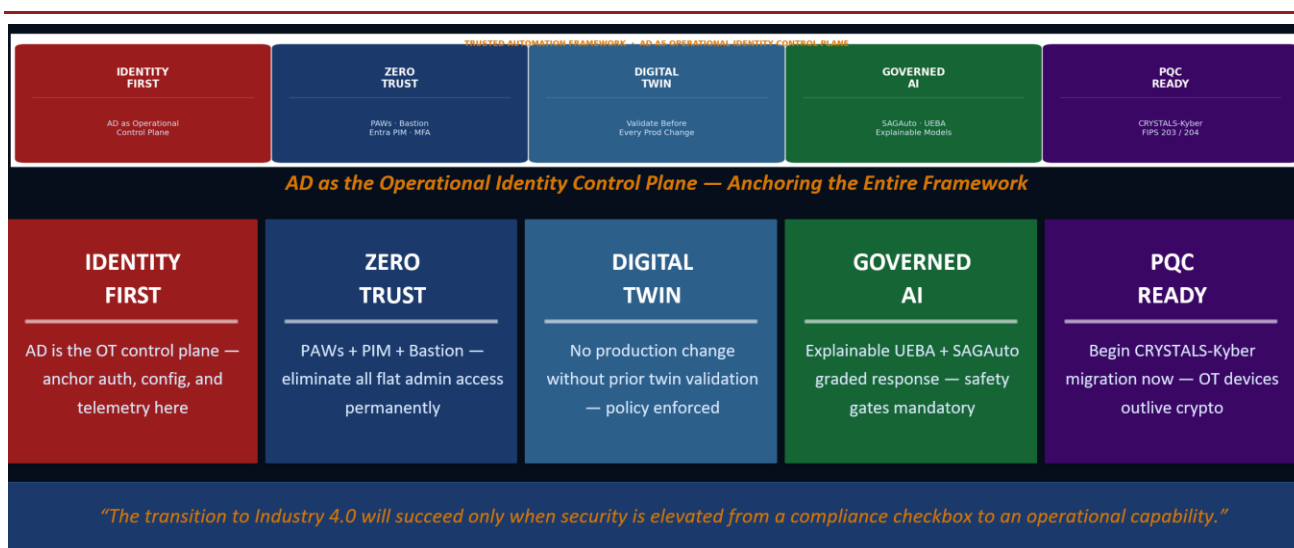


Figure 9 — Five Pillars of Trusted Automation: Identity First, Zero Trust, Digital Twin, Governed AI, and PQC Readiness — anchored by AD as the operational identity control plane.

The transition to Industry 4.0 will succeed only when security is elevated from a compliance checkbox to an operational capability. Active Directory, when modernised and properly hardened, is not a legacy artifact to be discarded — it is the **operational control plane for OT identity**: anchoring authentication, consolidating policy, and generating the telemetry that powers AI analytics, SIEM detections, and digital twin simulations. The five pillars represent the synthesis of this framework.

Zero Trust as Operational Reality

AD becomes the enabler of Zero Trust in OT: strict Tier-0 isolation on HCI, PAW-enforced administration, Entra Conditional Access and MFA on all privileged operations, just-in-time elevation via PIM, and Azure Bastion eliminating all exposed management ports. The result is an architecture that is **simultaneously more secure and more operationally resilient than the always-on, flat-network administration it replaces**.

Digital Twin Validation as Operational Standard

Digital twins proved indispensable across all three automotive pilots for testing access policies, patch rollouts, AI playbooks, and PQC algorithm swaps before any production contact. The principle is simple: **no significant**

AD, PKI, or security policy change should ever reach production without twin validation. This converts theoretical designs into evidence-based operational procedures with full rollback capability.

The Path to Immediate Action

Pilot A: AD modernisation on Azure Stack HCI with complete Tier-0 hardening, PAW deployment, Entra-bastioned privileged access, and digital twin validation. Commission

Pilot B: federated AI/UEBA deployment with PQC compatibility testing. Both pilots must produce measured KPIs – MTTD, MTTR, rollback frequency, compliance evidence – as repeatable architecture templates for scale-out across the full plant estate and supply chain.

Immediate priorities to authorise and commission this quarter

01	Commission AD Architecture Audit	4-week engagement: inventory all DCs, map IT/OT domain gaps, identify isolated OT forest opportunities across all plants.
02	Deploy PAWs + Entra PIM Immediately	Remove all direct DC RDP today. Enforce MFA and time-bound JIT admin on every privileged account. Zero exceptions.
03	Scope OT Digital Twin Pilot (1 Plant Zone)	Mirror DCs, AD CS, and one PLC control loop. Establish policy: no AD, PKI, or security change reaches production without twin validation.
04	Initiate PQC Readiness Assessment	Certificate inventory and gap analysis. Engage CA/HSM vendors for CRYSTALS-Kyber (FIPS 203) migration planning now.
05	Integrate OT AD with Unified SIEM	Kerberos, AD CS, and PAW session logs feed unified IT/OT SIEM. Deploy OT-aware detection rules. Measure MTTD baseline.

12. Strategic Roadmap and Key Focus Areas

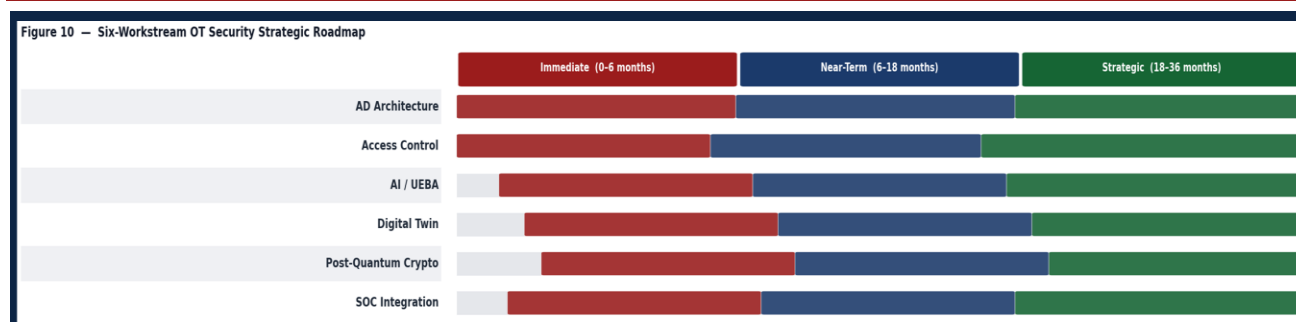


Figure 10 — Six-Workstream OT Security Strategic Roadmap: Immediate (0–6 mo, crimson), Near-Term (6–18 mo, navy), Strategic (18–36 mo, green), with staggered workstream starts.

The six-workstream roadmap maps all framework elements to three-time horizons. AD architecture and access control are immediate priorities that create the identity foundation all other workstreams depend upon. AI/UEBA, digital twin, PQC, and SOC integration follow sequentially, with strategic-phase activities building on operational baselines established in earlier phases.

Workstream	Immediate (0–6 mo)	Near-Term (6–18 mo)	Strategic (18–36 mo)
AD Architecture	Audit AD topology; inventory all DCs; map IT/OT domain and trust gaps	Deploy isolated OT forest or dedicated domain; local DCs in each zone	Full Tier-0 hardening; tested immutable backups; quarterly DR validation
Access Control	Deploy PAWs; enforce MFA on all privileged accounts; remove direct DC RDP	Entra Bastion + PIM JIT for all Tier-0 administration; remove legacy admin shares	Full Zero Trust posture; continuous device posture verification
AI / UEBA	Select platform; ingest AD and OT telemetry; establish identity baselines	Advisory detection mode; threshold tuning; SIEM and SOAR integration	SAG Auto soft containment (non-safety); full automated SOC playbooks
Digital Twin	Scope pilot twin: DCs, AD CS, selected PLC and SCADA control loops	Deploy in production support role; validate all changes via twin	Mandatory twin-first for every production AD, PKI, and security change
Post-Quantum Crypto	Certificate inventory; crypto gap assessment; CA/HSM vendor engagement	Shorten certificate lifetimes; CRYSTALS-Kyber hybrid pilot on Tier-0 DCs	PQC primary for all Tier-0; full FIPS 203/204 aligned to NIST IR 8547
SOC Integration	Define scope; instrument Tier-0 AD and PKI; establish KPI baselines	Deploy unified IT/OT SIEM; OT-aware detection rules; safety-gated playbooks	Automated graded response; KPI dashboards; quarterly red team exercises
Compliance & GRC	Full gap assessment: IEC 62443, NIST CSF, ISO/SAE 21434, NIS2	Remediate critical gaps; document governance framework and RACI matrix	Continuous posture monitoring; automated evidence collection for audits

References and Authoritative Sources

A. Standards and Regulatory Frameworks

- [1] IEC 62443-1-1 through 3-3 (2013–2022) – Industrial Automation and Control Systems Security. IEC.
<https://www.iec.ch/homepage>
- [2] NIST Cybersecurity Framework (CSF) v2.0. National Institute of Standards and Technology, February 2024.
<https://www.nist.gov/cyberframework>
- [3] ISO/SAE 21434:2021 – Road Vehicles: Cybersecurity Engineering. ISO/SAE International, August 2021.
- [4] NERC CIP Standards v7 – Critical Infrastructure Protection. North American Electric Reliability Corporation.
<https://www.nerc.com/pa/Stand/Pages/CIPStandards.aspx>
- [5] NIS2 Directive (EU) 2022/2555 – Network and Information Systems Security. Official Journal of the EU, December 2022.
- [6] NIST SP 800-82 Rev. 3 – Guide to Operational Technology Security. NIST, September 2023.

B. Microsoft Technical Documentation

- [7] Microsoft – Enterprise Access Model and Privileged Access Workstations. <https://learn.microsoft.com/en-us/security/privileged-access-workstations/privileged-access-access-model>
- [8] Microsoft Defender for IoT – OT Network Security. <https://learn.microsoft.com/en-us/azure/defender-for-iot/organizations/overview>
- [9] Azure Stack HCI / Azure Local – Well-Architected Guide. <https://learn.microsoft.com/en-us/azure/well-architected/service-guides/azure-stack-hci>
- [10] Microsoft Entra ID – Security Best Practices for Hybrid Identity. <https://learn.microsoft.com/en-us/entra/architecture/secure-best-practices>
- [11] Azure Bastion – Eliminate Exposed Management Ports. <https://learn.microsoft.com/en-us/azure/bastion/bastion-overview>
- [12] Microsoft Entra Privileged Identity Management (PIM). <https://learn.microsoft.com/en-us/entra/id-governance/privileged-identity-management/pim-configure>

C. Field Research and Threat Intelligence

- [13] Peters, D.G. – Active Directory in ICS: Lessons Learned from the Field. Digital Bond / S4 Conference, 2015.
- [14] IBM Security – Cost of a Data Breach Report 2024. IBM Corporation, July 2024. <https://www.ibm.com/reports/cost-of-a-data-breach>
- [15] Dragos Inc. – ICS/OT Cybersecurity Year in Review 2024. <https://www.dragos.com/year-in-review/>
- [16] Claroty – The Global State of CPS Security 2024: Business Impact of Disruptions. <https://www.claroty.com/resources/>
- [17] CISA – Securing Industrial Control Systems: A Unified Initiative. <https://www.cisa.gov/topics/industrial-control-systems>
- [18] NIST – How Digital Twins Could Protect Manufacturers from Cyberattacks. February 2023. <https://www.nist.gov/publications>

D. Post-Quantum Cryptography Standards

- [19] NIST FIPS 203 – Module-Lattice-Based Key-Encapsulation Mechanism (CRYSTALS-Kyber). NIST, August 2024.
- [20] NIST FIPS 204 – Module-Lattice-Based Digital Signature Standard (CRYSTALS-Dilithium). NIST, August 2024.
- [21] NIST IR 8547 (Initial Public Draft) – Transition to Post-Quantum Cryptography Standards. NIST, 2024.
<https://nvlpubs.nist.gov/nistpubs/ir/2024/NISTIR.8547.ipd.pdf>

E. Automotive and Smart Manufacturing Case Studies

- [22] Stellantis NV – AI-Enabled Innovations for Manufacturing Efficiency Across Global Facilities. Corporate Press Release, September 2024. <https://www.stellantis.com/en/news>
- [23] Continental AG – Vehicle Cybersecurity Engineering and Production Security Programme, 2024.
<https://www.continental.com/en/press/press-releases/>
- [24] LG Energy Solution & Siemens AG – Battery Manufacturing Intelligence Strategic Partnership. PRNewswire, October 2021.
- [25] Honeywell International – OT Cybersecurity Threat Landscape Report 2024. <https://www.honeywell.com/us/en/press/2024>